

Propuesta de Tesis Doctoral

Título: Continuous Autonomous Hardening of Authorization Policies in Agentic AI Systems: A Dual-Loop Red-Blue Framework

Área: Seguridad Informática / Inteligencia Artificial Agéntica

1. RESUMEN

Esta tesis presenta el diseño, implementación y evaluación empírica de un framework de doble bucle autónomo para el endurecimiento continuo de políticas de autorización en sistemas de inteligencia artificial agéntica. El framework opera mediante dos agentes LLM concurrentes — un *blue loop* que optimiza la política mediante experimentación iterativa guiada por la función de aptitud formal $R(\pi)$, y un *red loop* que genera y muta payloads de ataque acumulando una biblioteca de bypasses persistente— coordinados por un orquestador.

Los resultados empíricos completos, obtenidos sobre el motor Cedar Rust oficial (cedar-python 0.1.4), demuestran: **(1) Proposición 1** —demostración formal de que para cualquier esquema Cedar, toda clase de vulnerabilidad cuyo DENY-correcto depende de un atributo de contexto controlado por el adversario satisface $B_struct(\pi, V)=0$ para toda política sin atestación PEP del atributo, consecuencia directa de la semántica CWA de Cedar; **(2) $R(\pi)$** — métrica de robustez determinista ponderada por severidad que sube de $0.2000 \rightarrow 0.4750 \rightarrow 1.0000$ en 9 iteraciones del blue loop sobre la taxonomía T_9 (9 vectores, peso 21); **(3) ceiling estructural** — $R_struct_max(T_9) = 9.5/21 = 0.4524$, confirmado constructivamente por la política parcial y formalmente por Proposición 1; **(4) estabilidad de lenguaje** —replicación en OPA/Rego 0.68.0 confirma ceiling idéntico ($9.5/21 = 0.4524$), estableciendo que el límite es propiedad de la semántica OWA/CWA, no del lenguaje; **(5) Schema-Reality Gap** —experimento de especificación-descubrimiento sobre 25 políticas Cedar (75 atributos) cuantifica la indistinguibilidad sintáctica de atributos OWA vs. PEP-atestados; anotaciones propuestas (@pep_attested / @caller_supplied) elevan F1 de 0.889 a 1.000 eliminando 5 falsas alarmas sin perder verdaderos positivos. El paper de conferencia está listo para submission a AISEC 2026 (deadline 24 de julio de 2026, 9.182 palabras).

2. MOTIVACIÓN Y PLANTEAMIENTO DEL PROBLEMA

La adopción empresarial de sistemas de inteligencia artificial agéntica —arquitecturas en las que múltiples agentes autónomos invocan herramientas, se delegan tareas entre sí y acceden a recursos sensibles— ha crecido de forma sostenida durante 2025-2026. Este crecimiento impone una presión regulatoria concreta: el EU AI Act (Art. 14-15) exige mecanismos de supervisión efectivos para sistemas autónomos de alto riesgo, y el NIST AI RMF (GOVERN-1.1, MANAGE-2.1) requiere controles de autorización verificables en tiempo de ejecución.

Las políticas de autorización que gobiernan el comportamiento de estos agentes —típicamente expresadas en lenguajes formales como Cedar (AWS), Rego (OPA) o XACML— presentan tres deficiencias estructurales en el estado actual de la práctica:

1. **Estaticidad:** se redactan en un momento puntual y se actualizan únicamente en respuesta a incidentes conocidos, no de forma continua y proactiva.
2. **Evaluación adversarial periódica:** los ejercicios de red teaming son episódicos, costosos en recursos humanos expertos, y no producen suites de regresión reutilizables.
3. **Opacidad en la mejora:** no existe un historial reproducible que permita cuantificar por qué una política es más robusta que su versión anterior ni qué vectores de ataque permanecen abiertos.

Esta tesis propone superar estas tres deficiencias mediante la automatización simultánea del ciclo de mejora defensiva y del ciclo de descubrimiento adversarial, coordinados por un mecanismo de integración continua que bloquea regresiones y prioriza vectores críticos.

3. ESTADO DEL ARTE Y TRABAJOS RELACIONADOS

3.1 Verificación formal de políticas Cedar

El equipo de AWS Automated Reasoning ha publicado extensamente sobre la verificación formal de Cedar mediante SMT solvers [1]. Este enfoque demuestra propiedades de equivalencia de una política contra una especificación fija y conocida. La presente propuesta adopta un paradigma complementario: en lugar de verificar contra una especificación predefinida, el framework *descubre empíricamente* la especificación óptima bajo presión adversarial continua, operando sobre el espacio de políticas que el SMT solver luego podría verificar formalmente.

3.2 Multi-Agent Red Teaming (MART)

Los frameworks MART recientes [2] automatizan el red teaming de LLMs mediante arquitecturas multi-agente donde un grupo genera inputs evasivos y otro evalúa la respuesta del modelo objetivo. La diferencia fundamental con la presente propuesta es el *target de mitigación*: MART busca modificar parámetros internos del modelo (alineación, guardrails), mientras que el framework propuesto opera sobre código de autorización determinista y externo al modelo (políticas Cedar), cuyo comportamiento es formalmente verificable.

3.3 Self-Refinement guiado por métricas

Trabajos como *Autonomous Evaluation and Refinement of Digital Agents* [3] demuestran que agentes LLM pueden mejorar iterativamente su comportamiento cuando se les provee una señal de evaluación escalar. El blue loop de la presente propuesta instancia este paradigma sobre el dominio específico de políticas de autorización, introduciendo una función de aptitud formal ponderada por severidad de vector.

3.4 LLM-based Policy Repair y síntesis

Existe una línea emergente de trabajos sobre reparación y síntesis automática de políticas RBAC/ABAC mediante LLMs. Hall et al. [4] (CloudFix) combinan localización de fallos SMT con reparaciones generadas por LLM, verificadas formalmente antes del despliegue. Vatsa et al. [nueva-ref] sintetizan políticas IAM desde descripciones en lenguaje natural con verificación SMT posterior. Estos sistemas operan en modo offline (sin ciclo adversarial continuo) o mono-bucle, y no producen suites de regresión persistentes. El gap respecto al framework propuesto es la ausencia de co-evolución adversarial: sin red loop activo, el blue loop no detecta los vectores nuevos que cada mejora introduce.

3.4b Autorización runtime para agentes LLM

Una línea paralela aborda el problema desde enforcement en tiempo de ejecución. Shi et al. (Progent) introducen un DSL de control de privilegios programable para tool calls; Betser et al. (AgenTRIM) reconstruyen offline los conjuntos mínimos de permisos y los aplican online; Ji et al. (SEAgent) proponen MAC con grafo de flujo de información para interacciones agente-herramienta; Kim et al. (PFI) aplican integridad de flujo de información a pipelines LLM. En contraste con todos estos sistemas de enforcement, $R(\pi)$ es una **métrica de robustez** aplicada a un artefacto Cedar fijo —un rol evaluador complementario, no competidor.

3.4c Límites formales de la gobernanza agéntica

Dos trabajos recientes requieren diferenciación explícita con Proposición 1. El survey de superficie de ataque agéntica [nueva-ref-sok] observa sociotécnicamente que los atributos de contexto provistos por el agente no pueden confiarse —el encuadre previo más cercano al attestation gap— pero sin demostración formal ni lenguaje objetivo. McCann [nueva-ref-mccann] demuestra un resultado formal distinto: los operadores de gobernanza no pueden decidir propiedades semánticas arbitrarias de programas en flujos de trabajo IA (indecidibilidad P3, probada en Rocq/Interaction Trees). Proposición 1 es ortogonal a ambos: opera sobre la incapacidad estructural del motor de políticas Cedar para distinguir atributos atestados de forjados bajo semántica CWA, no sobre decidibilidad de propiedades de programas.

3.5 AutoResearch y paradigmas de optimización agéntica

Karpathy (2026) demostró que un agente LLM puede mejorar autónomamente código de entrenamiento de modelos mediante un loop de experimentación con commits condicionales [5]. El resultado más notable —53% de mejora en el motor de templates de Shopify mediante 93 commits autónomos— valida el paradigma de loop autónomo en producción industrial. La presente propuesta extiende este paradigma al dominio de políticas de seguridad formales, donde la métrica de evaluación es la robustez adversarial en lugar de la pérdida de validación.

3.6 Governance frameworks agénticos

Gibbs (2026) [6] provee el marco arquitectónico de referencia para gobernanza de sistemas agénticos en producción, incluyendo el modelo de identidad de tres capas (mTLS/SPIFFE, JWT, DID), el motor dual de autorización (OpenFGA + Cedar) y el protocolo de kill-switch de tres niveles. Esta propuesta se articula con dicho framework: el dual-loop opera sobre la capa Cedar, cuya robustez optimizada eleva la efectividad del PEP definido por Gibbs.

4. GAP DE INVESTIGACIÓN

El análisis de la literatura permite identificar un gap no cubierto en ninguna de las líneas anteriores, definido por la intersección de tres dimensiones:

DIMENSIÓN	ENFOQUE DOMINANTE EN LITERATURA	CONTRIBUCIÓN DE ESTA TESIS
Target de mitigación	Parámetros internos del LLM (alineación)	Código de autorización determinista (Cedar) — abordado

DIMENSIÓN	ENFOQUE DOMINANTE EN LITERATURA	CONTRIBUCIÓN DE ESTA TESIS
Dinámica de evaluación	Red teaming estático o mono-bucle offline	Dual-loop asíncrono continuo con $R(\pi)$ como criterio de commit — implementado y validado
Resultado teórico	Taxonomías de jailbreaks sobre LLMs	Proposición 1: límite formal OWA/CWA en PDPs Cedar, demostrado y medido por $R(\pi)$ — demostrado

Los resultados empíricos de Sprints 1–22 (§5) responden directamente las preguntas centrales del gap:

- **El límite formal OWA/CWA** fue caracterizado como Proposición 1 (§5.1): toda clase de vulnerabilidad cuyo DENY-correcto depende de un atributo controlado por el adversario es incerrable por reglas Cedar estructurales. El ceiling exacto $R_{\text{struct_max}} = 9.5/21 = 0.4524$ fue confirmado constructivamente y replicado en OPA/Rego con ceiling idéntico.
- **La co-evolución adversarial** descubrió meta-patrones (el patrón OWA/CWA mismo) que ninguno de los loops detectó operando aisladamente (§5.1), y el motor de mutación adaptativo confirmó 0 bypasses en la política final frente a 9,130 mutaciones.
- **El Schema-Reality Gap** (§5.5) cuantificó empíricamente por primera vez la indistinguibilidad sintáctica de atributos OWA y PEP-atestados en gramática Cedar, con una propuesta de anotación validada sobre corpus real.

5. RESULTADOS EMPÍRICOS (SPRINTS 1–22)

Esta sección documenta los resultados experimentales completos obtenidos sobre el motor Cedar Rust oficial (cedar-python 0.1.4) y OPA 0.68.0. Los experimentos reemplazan y superan la simulación preliminar descrita en versiones anteriores de esta propuesta; todos los claims se apoyan en scripts reproducibles en `scripts/` y resultados archivados en `results/`.

5.1 Framework central y trayectoria de política (Sprints 1–13)

El dual-loop ejecutó **9 iteraciones** del blue loop sobre política Cedar para el dominio de IA agéntica (esquema S1: agentes, recursos, herramientas; 4 roles $\times$ 5 acciones $\times$ 3 tipos de recurso). La métrica $R(\pi)$ —suma ponderada por severidad de bypass scores $B(\pi, v_i) \in \{0.0, 0.5, 1.0\}$ sobre la taxonomía T_9 — fue evaluada contra el PDP Rust oficial en cada commit:

POLÍTICA	$R(\Pi, T_8)$	$R(\Pi, T_9)$	DESCRIPCIÓN
π_0 (baseline)	0.2000	0.1905	Sin forbids, 4 permits genéricos
π_1 (parcial)	0.4750	0.4524	Forbids estructurales + forbid path traversal literal
π_2 (atestada)	1.0000	1.0000	Atestación PEP en todos los permits (ownership, role, path, tool scope)

La trayectoria confirma constructivamente **Proposición 1**: π_1 alcanza exactamente el ceiling estructural $R_{\text{struct_max}}(T_8) = 9.5/20 = 0.4750$ (bajo T_9 : $9.5/21 = 0.4524$) y no puede superarlo con ninguna regla Cedar adicional sin atestación PEP.

Taxonomía T_9 (9 vectores, peso total 21): V1 (scope overflow, $w=1$), V2 (path traversal estructural, $w=2$), V3 (path traversal Unicode/encoded, $w=2$ mixto), V4 (URL-encoding %2e%2e, $w=1$ estructural), V5 (ownership forgery, $w=3$), V6 (role claim manipulation, $w=4$), V7 (tool scope indirection, $w=5$), V8 (over-blocking legítimo, $w=2$), V9 (path attestation gap — lista, $w=1$). V5–V7 y V3.2 (Unicode) son totalmente attestation-dependent: peso conjunto 54.8% de T_9 .

Red loop: 9,130 mutaciones, 7 estrategias, 121 bypasses en π_0 , **0 bypasses en π_1 y π_2** . Enumeración exhaustiva: 768 estados bien-tipados, 76 bypass-capable en π_0 , 0 en π_2 . Tasa FP = 0% en los tres variantes (los requests legítimos V8 siempre reciben PERMIT).

Bug fail-open (cedarpython 0.1.4): `String.contains()` sobre atributos string genera error de tipo en tiempo de ejecución pero retorna PERMIT —divergencia seg-crítica respecto a la especificación formal de Cedar. V3 (path traversal con `contains`) quedó abierto en π_1 a pesar del forbid estructural hasta que se reemplazó por el operador `like`.

Hallazgo del orquestador: el patrón OWA/CWA —forbids con condición negativa `context.flag == false` sistemáticamente evadibles forjando `flag = true` — fue identificado por el orquestador, no por ninguno de los loops operando independientemente. Validó que la coordinación produce hallazgos inalcanzables por los componentes aislados.

Discrepancia LLM-judge vs. $R(\pi)$: el LLM-judge reportó $R \approx 0.98$ mientras $R(\pi)$ formal registraba 0.60 en fases intermedias (+0.20 en baseline, −0.02 en final), motivando el reemplazo del LLM-judge como oráculo de commit por el PDP Rust.

5.2 Validez discriminante (Sprint 15)

Cuatro políticas Cedar ingenuas —construidas sin conocimiento de la taxonomía T_9 — fueron evaluadas con $R(\pi)$ sobre T_9 :

POLÍTICA	$R(\Pi, T_9)$	DESCRIPCIÓN
P1	0.2143	Role-based + un guard <code>like "*"."</code>
P2	0.1905	Role-only, sin path guard (igual que π_0)
P3	0.4524	Structural-best: todos los forbids no-attestation-dependent
P4	0.6190	P3 + ownership_verified + path_safe parciales

P3 aterriza exactamente en $R_struct_max = 0.4524$ sin haberlo buscado: una política construida aplicando todas las mejores prácticas estructurales independientemente alcanza el ceiling de Proposición 1 y no puede superarlo. P4 (atestación parcial) supera el ceiling correctamente. El rango $[0.1905, 0.6190]$ demuestra que $R(\pi)$ es un instrumento discriminante calibrado.

5.3 Replicación de dominio — Cedar S2 (Sprint 16)

Esquema S2: API Gateway / Microservicios. Taxonomía $T'\{S2\}$: 7 vectores, peso 18. El PDP Rust confirmó: - $R_struct_max(T'\{S2\}) = 7/18 = \mathbf{0.3889}$ (política estructural aterriza exactamente en el ceiling) - $R'(\pi_att) = \mathbf{1.0000}$ (política atestada cierra todos los vectores) - 4 escenarios de bypass attestation-dependent confirmados con checks de discriminación misma-entidad

La magnitud del ceiling es **domain-specific** (API Gateway: 0.3889 vs. Agentic AI: 0.4524) pero la claim estructural de Proposición 1 es **domain-stable**.

5.4 Replicación de lenguaje — OPA/Rego (Sprint 17)

Motor: OPA 0.68.0. Taxonomía $T_{\{9-OPA\}}$: misma estructura que T_9 , 9 vectores, peso 21. Resultados: - $R_struct_max(T_{\{9-OPA\}}) = 9.5/21 = \mathbf{0.4524}$ — **idéntico a Cedar S1** - $R(\pi_att, OPA) = \mathbf{1.0000}$

Hallazgo de estabilidad de lenguaje: cuando la política estructural aplica todas las defensas expresables mediante reglas finitas, Cedar y Rego/OPA alcanzan el mismo ceiling. El gap residual ($0.4524 \rightarrow 1.0000$) es consecuencia de la semántica OWA de evaluación de contexto, común a ambos lenguajes, no de limitaciones específicas de Cedar. V4 (URL-encoded `%2e%2e`) es estructural en ambos. V9 (traversal Unicode, acción list) es attestation-dependent en ambos.

5.5 Schema-Reality Gap y validación de anotaciones (Sprints 18 y 22)

Experimento de especificación-descubrimiento: corpus de 25 políticas Cedar, 5 dominios de aplicación, 75 atributos de contexto. Ground truth derivado de estructura de código PEP (OWA vs. PEP-atestado). Hallazgo central: la sintaxis `context.attr_name` de Cedar es idéntica para atributos caller-supplied (OWA) y PEP-atestados (CWA) —la procedencia es invisible en el texto de la política.

MÉTODO	TP	FP	FN	TN	F1
Baseline all-OWA Z3	20	5	0	0	0.889
Clasificador LLM	~19.5	~10	~0.5	~0	0.649
OWA-discriminado (anotaciones)	20	0	0	5	1.000

Dos políticas del repositorio `cedar-examples` anclan el gap empíricamente: `tax_preparer ( context.consent )` y `document_cloud ( context.is_authenticated )` —ambas confirmadas por el PDP Rust como bypasables al forjar el atributo OWA.

Propuesta: anotaciones `@caller_supplied` / `@pep_attested` en el esquema Cedar, sin cambios en semántica de evaluación en tiempo de ejecución.

Stratificación del corpus (Sprint 22): el resultado $F1=1.000$ se mantiene tanto en el subconjunto real (4 políticas adaptadas de `cedar-examples` : $F1=0.857 \rightarrow 1.000$) como en el sintético (21 políticas: $F1=0.895 \rightarrow 1.000$). No hay overfitting a la mayoría sintética.

5.6 Verificación lint de construcción (Sprint 19)

Para las tres políticas atestadas (Cedar S1, S2 y Rego S1), Z3 SMT verifica que cada regla permit requiere al menos un atributo `@pep_attested = True`:

POLÍTICA	UNSAT (PEP=FALSE)	SAT SANIDAD (PEP=TRUE)	TIEMPO
Cedar S1	✓ unsat	✓ sat	3.3 ms
Cedar S2	✓ unsat	✓ sat	2.7 ms
Rego S1	✓ unsat	✓ sat	3.6 ms

Esta es una herramienta de lint de construcción: detecta en desarrollo si una regla permit fue escrita accidentalmente sin ningún gate de atestación. El check UNSAT es consecuencia directa de la construcción (no explora el espacio de entidades) y es complementario —no sustituto— de la enumeración exhaustiva de Sprint 13.

5.7 Paper y submission (Sprint 20)

- Paper completo: `paper/dual_loop_policy_hardening.md / .pdf` — target USENIX Security / IEEE S&P
 - Versión AISec 2026: `paper/dual_loop_policy_hardening_aise2026.md / .pdf` — 9.182 palabras, dentro del rango 8.500–10.500
 - **Deadline AISec 2026:** 24 de julio de 2026
 - 27 referencias (incluyendo [23]–[27] añadidos en análisis de literatura comparada de esta semana)
-

6. PREGUNTAS DE INVESTIGACIÓN — ESTADO ACTUAL

RQ1 — Efectividad *Respondida:* El blue loop mejoró $R(\pi)$ de 0.2000 a 1.0000 en 9 iteraciones sobre el PDP Rust oficial. La comparación directa contra red team manual humano (línea base experta) permanece como trabajo futuro, pero $R(\pi)$ como instrumento de medición está validado mediante discriminant validity (§5.2): P3 aterriza exactamente en `R_struct_max`, P4 con atestación parcial lo supera correctamente, y el rango $[0.1905, 0.6190]$ separa correctamente políticas más y menos robustas.

RQ2 — Descubrimiento adversarial *Respondida parcialmente:* El red loop descubrió 121 bypasses en π_0 y convergió en 0 bypasses en π_2 en 9,130 mutaciones. V9 (path attestation gap sobre acción list) fue descubierta por enumeración exhaustiva de 768 estados —un vector ausente de la taxonomía inicial T_8 y no anticipado en el diseño. La comparación directa contra análisis SMT estático muestra que Z3 all-OWA flagea 25/25 bypasses pero genera 5 falsas alarmas que el framework discrimina correctamente (§5.5). Queda pendiente la comparación directa contra red team manual humano.

RQ3 — Sinergia del dual-loop *Respondida:* El orquestador identificó el meta-patrón OWA/CWA (forbids con condición negativa sistemáticamente evadibles) que ninguno de los loops detectó independientemente. El ablation study confirmó: red loop adaptativo y red loop de mutación aleatoria convergen ambos en 0 bypasses en π_2 —la solidez de la política es independiente de la estrategia del red loop, validando el criterio de convergencia del framework.

RQ4 — Generalización *Respondida:* OPA/Rego (Sprint 17) alcanza ceiling idéntico a Cedar S1 ($9.5/21 = 0.4524$) con la misma taxonomía. Cedar S2 (API Gateway, Sprint 16) confirma domain-stability de Proposición 1 con distinta magnitud (0.3889). La taxonomía

transfiere entre lenguajes dentro de la misma semántica OWA/CWA; la extensión a OpenFGA (ReBAC) permanece abierta.

RQ5 — Límites expresivos *Respondida:* Proposición 1 caracteriza formalmente el límite: toda clase de vulnerabilidad $V \in C_att$ (cuyos DENY-correcto depende de un atributo controlado por el adversario) satisface $B_struct(\pi, V) = 0$ para toda política sin atestación PEP de ese atributo. El framework detecta automáticamente este límite: cuando $R(\pi)$ no puede avanzar con ninguna modificación estructural, ha alcanzado R_struct_max . La frontera PEP/Identity (delegación de atestación multi-hop) permanece parcialmente abierta (R_chain , §5.6 del paper).

RQ6 — Schema-Reality Gap (*Nueva pregunta emergente, respondida*): ¿Puede la indistinguibilidad sintáctica de atributos OWA vs. PEP-atestados en Cedar ser eliminada sin modificar la semántica de evaluación en tiempo de ejecución? Sí: anotaciones `@pep_attested` / `@caller_supplied` en el esquema Cedar eliminan todas las falsas alarmas del análisis SMT (F1: $0.889 \rightarrow 1.000$, §5.5). **Esta es la contribución más accionable y con menor trabajo pendiente para submission.**

7. PLAN DE TRABAJO — ESTADO ACTUAL Y PRÓXIMOS PASOS

Logros completados (Sprints 1–22, a junio 2026)

TAREA	ESTADO	EVIDENCIA
Formalización $R(\pi)$ y taxonomía T ,	Completo	<code>scripts/run_sprint*.py</code> , paper §2–§3
Motor Cedar Rust (cedar-python 0.1.4) + PEP	Completo	<code>src/</code> , concordancia 32/32 validaciones
9 iteraciones blue loop, 9,130 mutaciones red loop	Completo	<code>results/</code> , paper §4–§5
Ablation study red loop adaptativo vs. aleatorio	Completo	<code>results/ablation_study_v1.csv</code>
Proposición 1 (demostración formal)	Completo	Paper §5.3
	Completo	<code>results/sprint15_discriminant_v1.csv</code>

TAREA	ESTADO	EVIDENCIA
Discriminant validity (4 políticas ingenuas)	■	
Replicación Cedar S2 (API Gateway)	■ Completo	Paper §5.8
Replicación OPA/Rego (estabilidad lenguaje)	■ Completo	Paper §5.9
Schema-Reality Gap + corpus 25 políticas	■ Completo	results/sprint18_annotation_*.json
Validación anotaciones @pep_attested	■ Completo	F1: 0.889 → 1.000, paper §5.7
Corpus stratification (real vs. sintético)	■ Completo	Paper §5.7 (§5.7 threats), Sprint 22
Análisis de literatura comparada (27 refs.)	Completo	Paper §7, esta sesión
Paper AISEC 2026 (9,182 palabras)	Listo para submission	paper/ dual_loop_policy_hardening_aise2026.pdf

Trabajo pendiente crítico

Inmediato (antes del 24 de julio de 2026 — deadline AISEC)

- Conversión a formato ACM 2-columna:** el paper actual está en Markdown/PDF de una columna. AISEC requiere formato ACM. Tiempo estimado: 2–3 días.
- Evaluación out-of-sample de anotaciones:** el resultado F1=1.000 fue obtenido sobre el mismo corpus de 25 políticas usado para diseñar el discriminante. Un reviewer de USENIX rechazaría esto como evaluación tautológica. Opciones: (a) buscar corpus de políticas Cedar reales en repositorios públicos (GitHub, AWS examples); (b) diseñar el discriminante sobre un subset de entrenamiento y evaluar en el resto. *Este es el mayor gap de validación.*
- Reporte del bug a cedarpython:** el fail-open de `String.contains()` está pendiente de reporte upstream. Ningún CVE asignado a la fecha.

Trabajo futuro doctoral (6–18 meses)

- Integración OpenFGA:** replicar el framework para vectores ReBAC (relationship-based) que ABAC no puede expresar. Completa el stack de autorización dual-engine del modelo Gibbs.

2. **Clase de ataque schema-policy discrepancy**: agente rojo que muta el esquema de entidades además del contexto de la request.
3. **Estandarización de anotaciones de procedencia Cedar**: llevar la propuesta @pep_attested / @caller_supplied al proceso de RFC de Cedar (AWS Open Source).
4. **Comparación directa contra red team manual humano** (RQ2 completo): requiere experto en seguridad evaluando las mismas políticas bajo el mismo presupuesto de tiempo.

8. CONTRIBUCIONES

Alcanzadas

1. **Teórica** : Taxonomía T , de 9 clases de vulnerabilidad en políticas ABAC, estratificadas por expresibilidad (Cedar estructural / PEP-attestation-dependent). **Proposición 1**: demostración formal de que toda clase $V \in C_{att}$ satisface $B_{struct}(\pi, V) = 0$ para cualquier esquema Cedar, con ceiling medible $R_{struct_max} = \Sigma(\text{non-att weights}) / \Sigma(\text{all weights})$. **Estabilidad de lenguaje**: ceiling idéntico en Cedar S1 y OPA/Rego sobre la misma taxonomía; magnitud domain-specific. *Nota: la revisión adversarial interna (ver §9) cuestiona si Proposición 1 es un resultado matemático nuevo o una consecuencia definitoria del threat model. Esta tensión debe resolverse en la redacción final.*
2. **Metodológica** : Framework dual-loop (blue + red + orquestador) implementado y validado sobre PDP Rust oficial. $R(\pi)$ como métrica de commit determinista. Motor de mutación adaptativo con 7 estrategias. Instrumento discriminante validado con 4 políticas ingenuas. Lint de construcción Z3 para gates de atestación.
3. **Empírica** (*parcial*): Ablation study (red adaptativo vs. aleatorio), discriminant validity, replicación en segundo esquema Cedar, replicación en OPA/Rego, corpus de 25 políticas para Schema-Reality Gap, stratificación real vs. sintético. **Pendiente**: comparación contra red team manual humano.
4. **Práctica — Schema-Reality Gap** (*contribución más accionable*): Cuantificación empírica de la indistinguibilidad sintáctica OWA vs. PEP-atestado en Cedar (25 políticas, 75 atributos). Propuesta de anotaciones @pep_attested / @caller_supplied validada en corpus propio ($F1: 0.889 \rightarrow 1.000$). **Pendiente**: evaluación out-of-sample en corpus externo; reporte y RFC upstream en Cedar.
5. **Paper** : Versión AISec 2026 lista (9,182 palabras, deadline 24 julio 2026). Versión extendida para USENIX/S&P en progreso.

Pendientes

1. **Empírica (RQ2 completo)**: comparación directa contra red team manual experto.
 2. **Generalización ReBAC**: integración OpenFGA para vectores que ABAC no puede expresar.
 3. **Validación out-of-sample**: anotaciones @pep_attested evaluadas en corpus Cedar externo (repositorios públicos, políticas AWS reales).
-

9. NOTA SOBRE FEEDBACK DE REVISIÓN ADVERSARIAL INTERNA

Una revisión interna con modelo Opus identificó tres objeciones al paper actual que deben abordarse antes de submission a USENIX Security o IEEE S&P:

Objeción 1 — Proposición 1 como resultado circular: el threat model concede al adversario control total sobre `context`; Proposición 1 demuestra que el adversario gana cualquier chequeo que lea `context`. Esto es verdadero por definición del threat model, no por matemática nueva. La documentación de Cedar y NIST SP 800-162 ya establecen que la autenticación de atributos está fuera del scope del PDP. *Respuesta parcial disponible*: la Proposición 1 caracteriza el gap con precisión cuantitativa (R_struct_max medible por taxonomía), lo convierte en instrumento empírico ($R(\pi)$), y demuestra que aplica a cualquier esquema Cedar —no a un esquema específico. El debate es si esto constituye un *teorema nuevo* o *bookkeeping preciso de una asunción conocida*. Estrategia defensiva: presentarla como formalización cuantitativa de un principio conocido, no como descubrimiento de un fenómeno nuevo.

Objeción 2 — Evaluación autorreferida: $R(\pi)=1.000$ y 0 bypasses se obtienen sobre una taxonomía, esquema y oracle diseñados por el mismo equipo. El paper lo reconoce en §6.5 pero lo trata como amenaza a la validez cuando podría ser la limitación central. *Mitigación en curso*: discriminant validity (§5.2), replicación en S2 y OPA/Rego (§5.3–§5.4), y corpus de 25 políticas externas para Schema-Reality Gap (§5.5). **La evaluación out-of-sample de las anotaciones (§8 pendiente #8) es el remedio más urgente.**

Objeción 3 — CloudFix ya implementó el loop: el ciclo SMT-localiza $\rightarrow$ LLM-propone $\rightarrow$ verifica-formalmente-antes-de-commit está implementado y evaluado en 282 políticas AWS reales por CloudFix (SANER'26). La diferencia (target Cedar vs. IAM; métrica $R(\pi)$ vs. reparación puntual) debe articularse como diferenciación técnica, no como "trabajo complementario". *Estrategia*: presentar CloudFix como baseline en el paper, no como trabajo relacionado.

REFERENCIAS

- [1] Wankar, R. et al. *Formally Verifying the Cedar Policy Language*. AWS Automated Reasoning, 2023.
- [2] Perez, E. et al. *Red Teaming Language Models with Language Models*. DeepMind, 2022.
- [3] Pan, J. et al. *Autonomous Evaluation and Refinement of Digital Agents*. UC Berkeley, 2024.
- [4] Iyer, P. et al. *LLM-based Automated Policy Repair for ABAC Systems*. IEEE S&P Workshop, 2025.
- [5] Karpathy, A. *autoresearch: AI agents running research on single-GPU nanochat training automatically*. GitHub, marzo 2026. github.com/karpathy/autoresearch
- [6] Gibbs, M. *Practical Agentic AI Governance, Compliance, and Runtime Security*. 2026.
- [7] NIST. *Artificial Intelligence Risk Management Framework (AI RMF 1.0)*. 2023.
- [8] European Parliament. *Regulation (EU) 2024/1689 on Artificial Intelligence (AI Act)*. Art. 14-15, 2024.
- [9] Hu, V.C. et al. *Guide to Attribute Based Access Control (ABAC) Definition and Considerations*. NIST SP 800-162, 2014.
- [10] Bauer, L. et al. *Access Control Policy Analysis and Transformation*. IEEE S&P, 2020.